



A Guide to the Regulatory Information, Data and Reports to be provided by the Insurance Companies and Insurance-Related Professions



First: Introduction

The procedures and operations of the internal control, compliance and risk management have developed from the traditional to the modern methods emanating from the global professional associations, which laid down the international standards of the internal control, compliance, risk management operations in terms of planning and undertaking such activates, so that those in charge of these operations would focus on the riskiest fields.

The task of those employees can be summed up in ensuring that the operations, actions and procedures of the company in certain fields of the insurance industry are in line with the provisions in the State-enacted laws and, in particular, the laws, regulations, instructions and decisions of the Insurance Authority.

The Authority assures that the higher management has the responsibility for taking all necessary actions that would ensure objective and professional work performed by the staff of the Internal Control, Compliance and Risk Management Departments, especially in relation to providing the information and data and facilitating their work. The Authority also emphasizes that the staff should necessarily perform their work with high professionalism and objectivity free from any interest or pressure that would impact the integrity and impartiality of their reports.



General Provisions:

1. The insurance companies and the insurance-related professionals shall take due diligence to effectively regulate and control their affairs taking into consideration the nature, size, complexity and diversity of their operations and the risks faced by them. They must have suitable procedures and controls on the risk management.
2. The insurance companies must establish and maintain a governance framework stipulating that:
 - a. The responsibilities shall be distributed among the board directors, higher management and officers of the regulatory positions.
 - b. The regulatory tasks shall be separated from the responsibilities of the management.
 - c. The operations and affairs of the company shall be adequately monitored and controlled by the managers and the higher management.
 - d. Such strategies, policies, procedures and controls shall be established and maintained including the internal controls in commensuration with the nature, size and complexity of the operations and risk profile of the company.
3. They shall ensure that their policies, procedures and controls are regularly reviewed and updated as required.
4. The insurance companies shall create and maintain the internal control jobs as follows:
 - a. Risk management,
 - b. Compliance which includes combating financial crimes, anti -money laundering and countering terrorism financing, and
 - c. Internal audit.
 - d. The insurance companies can combine more than one of the internal control jobs above by performing them through the internal control staff. It should be emphasized that the combating of the financial crimes shall be carried on by a separate and specialized employee in this task.
5. The insurance-related professions shall create and maintain the internal control jobs as follows:
 - a. Risk management,
 - b. Compliance which includes combating financial crimes, anti -money laundering and countering terrorism financing,
 - c. Internal audit, and
 - d. The other jobs as they hold suitable for the nature, size and complexity of the insurance operations.
6. The operating insurance brokerage companies can authorize the internal controller who is registered with the Insurance Authority to perform all aforesaid internal control tasks till other directives will be issued by the Authority.



1. The insurance companies and the insurance-related professionals shall work on updating the information and data of the company in the electronic-systems of the Insurance Authority.
2. The company shall authorize whoever it holds suitable of its staff for periodically updating this data in accordance with the periods in the regulations, instructions and decisions on updating its information in the IA registers.
3. Some of the data and information shall be subject to the approval of the Insurance Authority in accordance with the requirements for necessarily applying Resolution No 15 of 2014 of the Board of the Insurance Authority on the Data and Information in the Register of the Insurance Companies and the Insurance-Related Professions.
4. The management and the internal control staff in the insurance companies and the insurance-related professions shall review and update the procedures of the company for updating its information and providing the data and reports on a quarterly basis.
5. The insurance companies and the insurance-related professions shall periodically review and update the following information according to the company's business nature as appropriate including for example without limitation:
 - a. General information about the company
 - b. The information in the enrollment and licensing records on which the company is registered
 - c. The information about the chairman and the directors of the board of the company
 - d. The information about the principal officers of the company
 - e. The information about the staff of the company
 - f. The information about the nationals working in the company and the information about the Emiratisation in terms of the training and compliance of the board of directors
 - g. The information about the branches of the company
 - h. The financial information about the capital, rating, deposits and bank guarantees of the company
 - i. The information about the certified external auditor and actuary of the company
 - j. The information about the major shareholders as per the shareholdings to be disclosed in accordance with the legislations in force
 - k. The name of the members of the governance committee in the company.
 - l. Information about the Compliance Officers.



Third: The Disclosures of the Insurance Companies and the Insurance-Related Professionals:

1. The insurance companies and the insurance-related professionals shall provide the interim and annual financial and technical statements and reports according to the provisions of Federal Law No 6 of 2007 on the Establishment of the Insurance Authority and the Regulation of its Operations as amended and the regulations, instruction, decisions and circulars issued thereunder.
2. The insurance companies and the insurance-related professionals shall as far as applicable to the nature of their operations and their legal forms as appropriate inform and provide the Authority with:
 - a. The convocation of the ordinary and extraordinary general meetings of the Company at least 15 days prior to the date of the general meeting.
 - b. The minutes of the general assembly within 7 days as of the date of the general meeting.
 - c. The dates and timings of the board meetings of the company in which this board will discuss decisions of the company which would affect the policyholders and beneficiaries such as the dividends, bonus shares, capital increase or reduction and the approval for new investment policies at least 2 days prior to the date of the meetings provided that they shall present the resolutions carried in this regard after the approval of the board immediately once they are carried.
3. The insurance companies and the insurance-related professionals shall inform and provide the Authority with:
 - a) All information and data provided by the company to any other regulatory authority and any data or information received by the company from such authorities within 2 working days.
 - b) The changes in the company's administrative structure at the level of the board and the executive management.
 - c) All or any substantial developments in the company at the level of the board and the executive management that would affect the financial conditions or the policyholders or beneficiaries once they occur such as the catastrophes, fire, merger, issuance of new securities, suspension of one of the production lines, voluntary liquidation and the cases filed by or against the company that would affect its financial position and expose it to serious loss whereby its chairman or the general manager must immediately inform the Director General within one business day.
4. The insurance companies shall provide the Authority with the approved forms of the insurance documents and their annexes according to Administrative Decision No 140 of 2019 on the Exclusion of Certain Insurance Documents from the Requirement of Being Drawn up in Arabic.
5. The insurance companies and the insurance-related professionals shall provide all required data and statistics in accordance with the Authority-set periods.



Fourth: Reports on Governance and Adherence

- **The Self-Assessment Form and the Annual Report on Governance**

1. The insurance companies and the insurance-related professionals shall as far as applicable to the nature of their operations and their legal forms as appropriate provide the Authority with a self-assessment of the governance procedures of the company in the intended completed e-form when the annual financial statements and reports are presented.
2. The insurance companies shall provide the Insurance Authority with a copy of the annual governance report filed by it every year when it presents its governance self-assessment form.
3. The governance self-assessment form shall comprise the following cornerstones:
 - a. The rights of the shareholders and policyholders
 - b. The general assembly.
 - c. Related party transactions.
 - d. Disclosure and transparency.
 - e. Internal audit.
 - f. Board committees.
 - g. Training.
 - h. Internal controls.
 - i. Any other matters as held necessary by the Authority.

- **Risk and Adherence Self-Assessment Forms**

1. The insurance companies and the insurance-related professionals shall fill in their risk and compliance self-assessments in accordance with the Authority-fixed periods in this regard in the intended e-form.
2. The risk and adherence self-assessment form shall comprise:
 - a. The insurance risks including the risks of the product, design, pricing and underwriting.
 - b. The credit risks.
 - c. The market risks including the investment and liquidity risks
 - d. The operational risk including the legal risks.
 - e. The organizational risks
 - f. The risks of the related parties
 - g. The risks of the financial crime.
 - h. The insurance fraud risks.
 - i. The cyber risks.
 - j. Other risks as specified by the Authority.



Fifth: Internal Audit & Risk Management Reports

- **Internal Audit Reports**

1. The insurance companies and the insurance-related professionals shall enable the internal audit staff to provide the Authority with the annual internal audit reports of the companies when the annual financial statements and reports are presented every year as well as Form No. (1) as hereto attached.
2. The internal audit report must comprise:
 - a. An executive summary of the internal audit process.
 - b. A short background.
 - c. The objective and scope of participating in the audit.
 - d. The methodology used.
 - e. The main findings.
 - f. The recommendations.
 - g. The challenges.
3. The internal audit staff of the insurance companies and the insurance-related professionals must fill in the intended e-form of the internal audit report when they submit a copy of the annual internal audit report according to the Report Form No (2)as hereto attached.

- **Risk Management Reports:**

1. The insurance companies and the insurance-related professionals shall fill in the intended e-form of the risk management of the companies when the annual financial statements and reports are presented according to the Form No(3) as hereto attached.
2. The insurance companies and the insurance-related professionals can provide the Authority with a copy of their risk management form which is associated with the e-report above.

Sixth: The Reports on Anti-Money Laundering and Combating the Financing of Terrorism and Financing of Illegal Organizations:

1. The insurance companies and the insurance-related professionals shall appoint a Compliance Officer to combat money laundering and terrorism financing as required by the laws, regulations, instructions, decisions and circulars in force.
2. The insurance companies and the insurance-related professionals shall enable the staff specialized in anti-money laundering and combating the financing of terrorism to perform their work and send the periodic reports to the Insurance Authority.
3. The Compliance Officers and the internal control staff must perform their work in a highly objective and professional way.
4. The insurance companies and the insurance-related professionals must shape policies and procedures for combating the financial crimes including money laundering and the financing of terrorism and illegal organizations.



5. The insurance companies and the insurance-related professionals shall present periodic reports as follows:
 - a. The reports prepared by the Compliance Officers.
 - b. The reports prepared by the internal control staff concerning the effective internal controls for anti-money laundering and combating terrorism financing.
 - c. The report of the certified external auditor of the company concerning the effective internal controls for anti-money laundering and combating terrorism financing.
 - d. The self-assessment reports prepared by the Compliance Officers including:
 1. A biannual self-assessment report in the intended e-form of the Insurance Authority to be filed prior to the end of 15 August every year in the e-systems of the Authority.
 2. An annual self-assessment report in the intended e-form of the Insurance Authority to be filed prior to the end of 15 February every year in the e-systems of the Authority.
 - e. The Compliance Officers must attach their internal reports on the internal work policies, regulations and procedures to aforesaid electronic self-assessment reports according to the following determinants:
 - The regulations and policies on anti-money laundering and combating terrorism financing.
 - The internal regulations on the risk-based approach
 - Customer due diligence
 - • Enhanced customer due diligence.
 - Continuous due diligence.
 - The (STRs) suspicious Transaction Reports.
 - Compliance Officers.
 - Record keeping.
 - Training.
 - f. All or any reports required by the Authority concerning the data and statistics on anti-money laundering and combating terrorism financing according to the Authority-set periods.
 - g. The reports prepared by the internal audit staff concerning the effective internal controls for anti-money laundering and combating terrorism financing.
6. The internal control staff of the insurance companies and the insurance-related professionals must file an annual report by the end of April every year on reviewing the internal policies, regulation and procedures for anti-money laundering and combating the financing of terrorism according to the intended E-Form No (4) as hereto attached.



7. The internal audit report must contain:
 - a. An executive summary of the internal auditing.
 - b. A short background
 - c. The objective and scope of participating in the audit
 - d. The methodology used
 - e. The main findings.
 - f. The recommendations.
 - g. The challenges.
8. The report prepared by the internal control staff must imply a comprehensive review of at least the following internal controls:
 - a. The regulations and policies for anti-money laundering and combating terrorism financing .
 - b. The internal regulations on the risk-based approach.
 - c. Customer due diligence.
 - d. The enhanced the customer due diligence.
 - e. The continuous due diligence.
 - f. The (STRs) Suspicious Transaction Reports.
 - g. Record keeping.
 - h. Training.
 - i. All or any other additional controls.
9. The internal control staff can upload their report on reviewing the internal controls of the company associated with the e-report above.
10. The report of the certified external auditor of the company concerning the effective internal controls for anti-money laundering and combating terrorism financing shall be in accordance with the following:
 - a. The insurance companies and the insurance-related professionals shall fill in the e-form of the annual report prepared by the company's external auditor when the audited annual financial statements and reports are provided to the Authority in Form No. (5) as hereto attached.
 - b. The Authority must be provided by the company with a copy of the duly signed report of the external auditor when the e-report above is presented provided that the report shall comprehensively review at the least the following internal controls:

Scope	Details
Suspicious Transactions Reports	- Verifying from the Compliance Officer the applicable policies and procedures to ensure that any of the staff that deals or has an administrative liability for dealing with the transactions, which may involve money laundering or terrorism financing, files an immediate report to the Compliance Officer of the company, if



	he/she comes to know about a suspicious operation, and freezes the transactions. - Verifying from the Compliance Officer if there are any suspicious or unusual transactions notified by the staff and if the FIU of the Central Bank of the UAE is notified of it after verifying that it is suspicious or unusual. - Obtaining STR and SAR records, it should be confirmed if such reports are urgently notified only to the FIU of the Central Bank of the UAE, (ensuring that the reports are not filed to another regulator). - Verifying from the Compliance Officer the applicable procedures to ensure that the higher management, officers and staff do not notify or inform by any (written or phone) means the (customer, the beneficiary or any related profession) about their information, notifying the relevant authorities and verifying that the company has policies, procedures, regulations and controls to prevent informing the customer in this event - Verifying if the examined samples imply any contact or refers to a communication with the customer to inform him/her/it that he/she/it is a suspect - Verifying that STR and SAR are timely filed to the FIU of the Central Bank of the UAE, describing the nature of the transactions which raise suspicion, and verifying if the notified transactions are timely frozen. - Verifying that the company has an activated account in "GO-AML" and the number of STR and SAR sent to the FIU during the year.
Compliance Officer	- Verifying the documents of the appointment or assignment of any of the company's employees as a (Compliance Officer) and requesting the documentary evidence of the appointment/assignment which were notified to the Insurance Authority - Verifying through the administrative structure that the (Compliance Office) filed his/her reports directly to the higher management of the company and that there are no other tasks assigned to the Compliance Officers - Ensuring that the Compliance Officer is responsible for all obligations in Article 21 of Cabinet Resolution No 10 of 2019 on the Executive Regulations of Federal Law No 20 of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Financing of Illegal Organizations - Verifying that the company asked the appointed external auditors to prepare and file a report on the compliance with Law on Anti-Money Laundering to the Insurance Authority by 30 April of the next year and that the findings of such report were received and addressed by the company.



	Verifying the qualifications of the (Compliance Officer), (including the professional certificates and the training courses attended by the (Compliance Officer) - Verifying that the (Compliance Officer) files a biannual report to the higher management and the Insurance Authority.
Due Diligence procedures	1) Performing all obligations for “Know Your Customer”, customer due diligence and enhanced due diligence as set out in Cabinet Resolution No 10 of 2019 on the Executive Regulations of Federal Law No 20 of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Financing of Illegal Organizations: a. For natural persons, as set out in the above Cabinet Resolution. b. For corporate persons, as set out in the above Cabinet Resolution. c. For NGOs, as set out in the above Cabinet Resolution. d. In the event of conducting transactions for another person or entity, verifying the identity of such person or entity and obtaining the required information and documents, as set out in the above Cabinet Resolution. 2) Verifying from the staff of the company if all necessary information and documents of the customers, including the ultimate beneficiary owners, are obtained prior to establishing any business relationships, whether the customer is a natural or corporate person, and if such information is regularly updated 3) Verifying from the Company if the applicable procedures establish the identity of the beneficiaries, which are not the customer, obtaining and recording full information there, and ensuring whether: a) The company determines and verifies the identity of this party prior to conducting any payment transactions b) In the event of identifying the beneficiary as a corporate person or taking a legal arrangement with high risk, the customer due diligence procedures of the company shall include procedures based on premises to determine and verify the real identity of the beneficiary of the insurance policy upon payment 4) Ensuring through the staff of the company whether the customer due diligence procedures are adopted:



	a) The company takes measures based upon premises to understand the ownership and nature of the corporate person b) The company ensures the nature and type of the business relationship, which is established with a natural or corporate person c) The company controls on a continuous basis the business relationship with its customers, to the effect that it verifies the transactions conducted to ensure that they are in accordance with KYC and the details of the customer business and its risks as well as the source of the funds, as required. 5) Verifying if the company enters into business with a customer by using a false name or with an unknown person or opening an account with a fictitious name and if the name of the account holder is in accordance with the identity card or a copy of the passport or the trade license and if the staff in charge verifies that such copies are authentic and signed. 6) Verifying from the staff of the company if the following procedures and terms are adopted and complied with: a. Applying the due diligence procedures to the current customers, if: (1) There is a substantial change in the nature or ownership of the customer (2) There is doubt about the correctness or accuracy of the information of the customer (3) A big transaction is about to be concluded with or for the customer (4) There is another reason that may be held adequate by the company b. If the company is unable to identify the customer by a reliable and independent source of information, the company must: 1) End any relation with the customer immediately. 2) Consider the need for filing suspicious transaction reports to the competent unit.



Enhanced Due Diligence	Performing all obligations for “Know Your Customer”, customer due diligence and enhanced due diligence, as set out in Cabinet Resolution No 10 of 2019 of the Executive Regulations of Federal Law No 20 of 2018 on Anti-Money Laundering and Combating the Financing of Terrorism and Financing of Illegal Organizations 1) Verifying that the company has a process for identifying the customers and/ or the real beneficiaries from the politically exposed persons (PEP) and ensuring that: a. Suitable risk management regulations are applied to determine whether the customer or the real beneficiary is a PEP or not. b. The approval of the higher management is obtained for establishing or proceeding with a business relationship, if the customer or the real beneficiary is a PEP. c. The source of the wealth and assets of the real beneficiary is determined by any available reasonable means. d. It during the business relationship conducts enhanced due diligence. 2) In the event of large documents, as specified in Article 6 of Cabinet Resolution No 10 of 2019 above, verifying that the documents of the financial situation of the customer, the source of the funds and the net income as well as the names of the banks, which the customer deals with, are kept and maintained over the past three years. 3) Ensuring that the company provides, in addition to the due diligence procedures, the due diligence under Cabinet Resolution No 10 of 2019 above. 4) Ensuring that the insurance company takes reasonable measures to identify the beneficiary or the beneficial owner of the life insurance and Family Takaful insurance policies. If he/she is identified as a PEP, the company shall inform the higher management prior to paying to the beneficiaries or prior to exercising any rights thereof, do a comprehensive examination of all business relationships and consider notifying a STR to the Unit
Maintaining Documents	- The number of the years of maintaining the documents (in the event of a court case and after the end of the court case or in the event that there is no legal action) - The existing transaction details (type, sum, etc.), including whether an STR or SAR is notified - The method of maintaining the data (in soft or hard files) - The existing system for document maintenance - If the system includes the dates of the commencement and end of the business relationship



	In the event of notifying STR or SAR, whether the database contains a request from the FIU and what is the timeframe of dealing with such requests - The minimum requirements for storing (soft and hard) records, which may include the safety and the availability of the data in the event of a crisis
Risk-Based Approach	The company relays on a risk-based approach, which includes: - Assessing the risks of money laundering and financing of terrorism faced by the company, including a. The type of the company's customers (and the purpose of the relationship) b. The products and services provided by the Company (and their objective) c. The technology used by the company (and the objective of this use) to provide such products and services - Establishing the required procedures for mitigating such risks - The existing classification and description of the risks of the business relationship, taking into consideration at least four risk factors of this business relationship: customer risk, product risk, operational risk and competent department risks
Policies & Procedures	Ensuring that the policies and procedures: - Are authenticated and approved for anti-money laundering and combating terrorism financing. - Include specified actions and standards for identifying the customers with high risk. - Include a specified and periodic mechanism for updating the lists of terrorism in Cabinet Resolution No 20 of 2019 and informing the regulator if the case is identified - Include the standards for notifying STR or SAR, (including the notification timeframe). - Require a timeframe for the regular update of the policies and procedures - Performing by the internal auditor a regular audit of the procedures for anti-money laundering and combating terrorism financing, which are adopted by the departments of the company - Verifying if the company adopts a policy for periodically reviewing the sufficient customer due diligence and enhanced due diligence for the customers and ultimate beneficiary owner and ensures a continuous update of the information, particularly, about the customers with high risk. - Verifying that the company adopts a process for periodically and regularly updating the tests of AML diligence.



AML Systems & Control	Verifying that: - An independent internal control unit exists in the company and inquiring from the internal auditor about the way of ensuring compliance with the policies, procedures, regulations and controls for anti-money laundering and combating terrorism financing. - The internal auditor files his/her reports to the audit committee. - Verifying from the Compliance Officer that there are confidential information agreements with the related professions, with which the company deals. - Verifying from the compliance officer that the information about the company is disclosed only as far as required in the investigations or the court cases, which are subject to the applicable legislations of the State - The company adopts and adheres to procedures for anti-money laundering and combating terrorism financing applicable to all of its branches inside and outside the UAE. - If the requirements for anti-money laundering and combating terrorism financing in the host country are less strict than the UAE requirements, the company applies all UAE requirements save for anything not permitted under the laws and regulations of the host country. - In the event that the branch or the subsidiary, which operates abroad, is unable to adhere to the highest standards, the company notifies the Insurance Authority of the matter and adheres to the additional directives dedicated by the Authority.
Staff Trainings & Employment	- Verifying if the training of the (Compliance Officer) and all staff remains updated and suitable for the activities of the company and the different customer types, and if the training is provided on a regular and continuous basis - Ensuring that the (Compliance Officer) does a periodic examination of all (newly appointed staff – current staff) - Verifying that a high level scientific training is provided to the (compliance officer)
Continuous Control	- Reviewing and updating the AML procedures on a regular basis - Verifying that the (Compliance Officer) ensures a continuous examination of all databases of the customers of the company and compares such examination with the terrorist lists in the law and legislations in force

Full compliance with Cabinet Resolution No 20 of 2019 on the Regulations of the Terrorist Lists and implementing the Security Council's Resolutions concerning the Prevention and Suppression of Terrorism and its Financing and Proliferation of Armaments and the Relevant Resolutions shall be completely implemented.



1. The details of those on the lists of the sanctions committees, (as defined in said Resolution) shall be followed up on a daily basis by directly referring to the resolutions approved by the Security Council and registering to this end on the website of the Executive Office of the Committee for Goods and Materials Subjected to Import & Export Control: <https://uaeiec.gov.ae/ar-ae/United-Nations-Security/Council-Saction>
2. The customer databases and any information obtained about the potential or current customers shall continually be verified and compared with the names on the penalty list. An updated list shall be maintained in a database of the terrorist persons and organizations on such list.
3. The Authority shall be immediately notified in the event that funds are frozen so that it shall notify the Executive Office of the Committee for Goods and Materials Subjected to Import & Export Control in accordance with the provisions of the legislations in force.
4. The Authority shall be notified if it is found that one of the previous customers of the company or any incidental customer which the company dealt with is a person or an organization on the penalty list.
5. The Authority shall be notified of not taking action as a result of similar names and failing to eliminate such similarity by the available or accessible information.



Internal Audit Report

Form number (1)

Internal Audit report for “name of insurance company “

Period of review: Timeframe of the review

Date of Final Report: Date of submission to the Mgt.

Name of Auditors Names of auditors involved



- 1- **Executive Summary** This section should contain the following
 - A brief background;
 - Objective and the scope of audit engagement;
 - Methodology;
 - Key findings;
 - Opinion;
 - Recommendations;
 - Limitations
- 2- **Background** This section should contain the following;
 - A brief background on the auditee;
 - Brief description of duties/functions of auditee;
- 3- **Objective and Scope**
 - Elaborate on the objective and scope of audit engagement and period covered by the current audit.
- 4- **Methodology**
 - This section should explain the methodology adopted to conduct internal audit vis-à-vis interview, observation, sampling, sample size and others used for test checking records, number of records checked, type of records checked.
- 5- **Recommendations**
 - This section will contain general recommendations if any that could not be covered as part of recommendations in the specific audit observations.
- 6- **Conclusion**
 - This section should constitute the auditors' overall opinion about the functioning of the auditee unit with respect the overall objective of the audit engagement.
 - The strength of the auditee agency may be highlighted in this section along the areas needing attention and corrective action.
- 7- **References**

This section should list all publish or unpublished materials used and referred in coming with the Internal Audit Report.
- 8- **Limitations**
 - Describe all your limitations in here. The limitations can be related to scope of the audit, methodology adopted, adequacy of the samples and adaptation of standards.



Internal Audit Report					
FINDING	POTENTIAL EFFECT	RECOMMENDATION	PRIORITY *	MANAGEMENT RESPONSE	TARGET DATE

Priority ratings have been assigned to issues raised in this report as follows:

*PRIORITY OF INDIVIDUAL RECOMMENDATIONS	
Extreme Priority.	Internal Audit considers the implementation of this recommendation to be fundamental to the proper working of the system. It should normally be carried out within 1 month of the report's issue
HIGH	Internal Audit considers the implementation of this recommendation to be important to the proper functioning of the system. It should be carried out normally within 3 months of the report's issue.
MEDIUM	Internal Audit considers that it would be aided or improved by its implementation. It should normally be carried out normally within 6 months of the report's issue.
LOW	The system's effective operation may not depend upon this recommendation, but Internal Audit considers that it would be aided or improved by its implementation. It should normally be carried out normally more than 6 months of the report's issue.



Risk Assessment as of [DATE]						
Identified Risks and Schemes	Likelihood	Significance	Risk Rating	Controls Effectiveness Assessment	Residual Risks	Risk Response (List an action plan on how each residual risk will be mitigated)
Insurance risk						
Credit risk						
Market risk						
Operational risk						
Regulatory risk						
Contagion and related party risk						
Financial crime risk						
Cyber risk						
Strategic risk						
Regulatory Risk						



Likelihood

<u>Rating</u>	<u>Based on Annual Frequency</u>		<u>Based on Annual Probability of Occurrence</u>	
	<u>Descriptor</u>	<u>Definition</u>	<u>Descriptor</u>	<u>Definition</u>
5	Very frequent	More than twenty times per year	Almost certain	>90% chance of occurrence
4	Frequent	Six to twenty times per year	Likely	65% to 90% chance of occurrence
3	Reasonably frequent	Two to five times per year	Reasonably possible	35% to 65% chance of occurrence
2	Occasional	Once per year	Unlikely	10% to 35% chance of occurrence
1	Rare	Less than once per year	Remote	< 10% chance of occurrence

Significance

<u>Rating</u>	<u>Descriptor</u>
5	Catastrophic
4	Major
3	Moderate
2	Minor
1	Incidental



Control Effectiveness

Control Risk Rating	Description
5	Very effective (reduces 81–100% of the risk)
4	Effective (reduces 61–80% of the risk)
3	Moderately effective (reduces 41–60% of the risk)
2	Marginally effective (reduces 21–40% of the risk)
1	Not effective (reduces 0–20% of the risk)

OVERALL ASSURANCE

FULL “ Very effective”	Full assurance that the system of internal control is designed to meet the organisation’s objectives and controls are consistently applied in all the areas reviewed
SIGNIFICANT “ Effective”	Significant assurance that there is a generally sound system of control designed to meet the organisation’s objectives. However, some weakness in the design or inconsistent application of controls put the achievement of particular objectives at risk.
LIMITED “ Moderately effective”	Limited assurance as generally moderate sound system in the design or inconsistent application of controls put the achievement of the organisation’s objectives at risk in the areas reviewed.
Very LIMITED “ Marginally effective”	Limited assurance as weaknesses in the design or inconsistent application of controls put the achievement of the organisation’s objectives at risk in the areas reviewed.
NO ASSURANCE	No assurance as weaknesses in control or consistent non-compliance with key controls could result (have resulted) in failure to achieve the organisation’s objectives in the areas reviewed.



Residual Risks for individual findings	
High	Active management attention required as a high priority. Controls are not adequate to address the associated risk.
Medium	Active management attention required as a moderate priority. Controls are not adequate to address the associated risk.
Low	Active management attention not required on priority. Controls are more or less adequate to address the associated risk.



Internal Audit Report

Controls	Finding	Potential effect	Recommendation	Priority	Management response	Target date	Effectiveness From (1-5)
AML/CFT systems							
Policies and procedures							
Risk-Based Approach ("RBA")							
Customer Due Diligence – CDD							
Suspicious Transaction reports							
Record Keeping							
Training							
AML Officer , Compliance Officer							
Ongoing monitoring							
Enhanced Due Diligence ("EDD")							
ETC....							



Form number (5)

External Audit Report		
Procedures	FINDING	Effectiveness From (1-5)
Risk-Based Approach ("RBA")		
Customer Due Diligence - CDD		
Suspicious Transaction reports		
Record Keeping		
Training		
AML Officer , Compliance Officer		
Ongoing monitoring		
Enhanced Due Diligence ("EDD")		
ETC....		